

VPN Compromise & Lateral Movement Investigation

Logs Captured

- Firewall Logs: firewall.log
- WAF Logs: ids_alerts.log
- VPN Logs: vpn_auth.logs

Manual log Analysis via command line interface:

1. I used the "head" command (`head firewall.log`) to open the file and view all firewall traffic in the terminal.

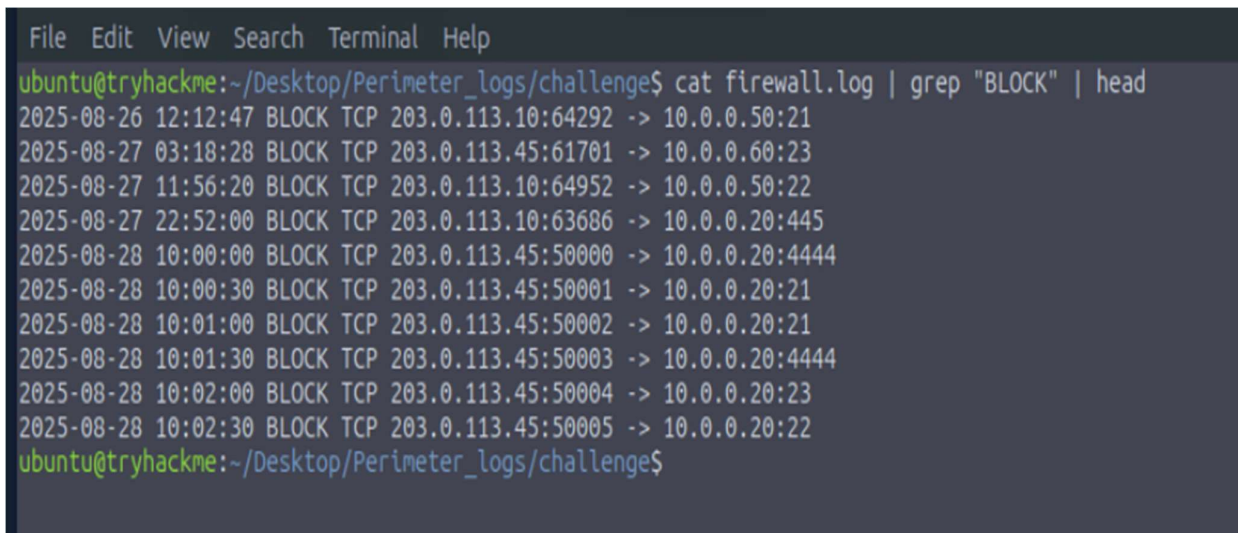
Same with the VPN Logs and WAF Logs

`head ids_alerts.log`

`head vpn_auth.log`

2. After exploring the data I started my recon attempt.

I used the command [`cat firewall.log | grep "BLOCK" | head`] to pull all blocked requests



```
File Edit View Search Terminal Help
ubuntu@tryhackme:~/Desktop/Perimeter_logs/challenge$ cat firewall.log | grep "BLOCK" | head
2025-08-26 12:12:47 BLOCK TCP 203.0.113.10:64292 -> 10.0.0.50:21
2025-08-27 03:18:28 BLOCK TCP 203.0.113.45:61701 -> 10.0.0.60:23
2025-08-27 11:56:20 BLOCK TCP 203.0.113.10:64952 -> 10.0.0.50:22
2025-08-27 22:52:00 BLOCK TCP 203.0.113.10:63686 -> 10.0.0.20:445
2025-08-28 10:00:00 BLOCK TCP 203.0.113.45:50000 -> 10.0.0.20:4444
2025-08-28 10:00:30 BLOCK TCP 203.0.113.45:50001 -> 10.0.0.20:21
2025-08-28 10:01:00 BLOCK TCP 203.0.113.45:50002 -> 10.0.0.20:21
2025-08-28 10:01:30 BLOCK TCP 203.0.113.45:50003 -> 10.0.0.20:4444
2025-08-28 10:02:00 BLOCK TCP 203.0.113.45:50004 -> 10.0.0.20:23
2025-08-28 10:02:30 BLOCK TCP 203.0.113.45:50005 -> 10.0.0.20:22
ubuntu@tryhackme:~/Desktop/Perimeter_logs/challenge$
```

3. After assessing the blocked requests, we find that a single IP Address is probing against various ports.

I then used the command [`cat firewall.log | grep [REDACTED] | grep "ALLOW"`] to see if the firewall has allowed any requests to the suspicious IP

```

File Edit View Search Terminal Help
2025-09-22 06:49:55 ALLOW TCP 198.51.100.92:60380 -> 10.0.0.51:443
2025-09-22 07:00:00 ALLOW TCP 10.0.0.60:30045 -> 198.51.100.77:4444
2025-09-22 07:00:00 ALLOW TCP 10.0.0.51:40020 -> 198.51.100.77:80
2025-09-22 07:54:49 ALLOW TCP 198.51.100.77:55526 -> 10.0.0.20:25
2025-09-22 08:03:44 ALLOW TCP 198.51.100.45:56608 -> 10.0.0.60:53
2025-09-22 08:36:26 ALLOW TCP 198.51.100.77:63186 -> 10.0.0.51:53
2025-09-22 08:58:36 ALLOW TCP 198.51.100.77:58414 -> 10.0.0.51:8080
2025-09-22 09:59:57 ALLOW TCP 192.0.2.115:58815 -> 10.0.0.60:8080
2025-09-22 10:16:58 ALLOW TCP 198.51.100.45:52629 -> 10.0.0.51:8080
2025-09-22 10:45:32 ALLOW TCP 192.0.2.115:54313 -> 10.0.0.51:443
2025-09-22 11:00:00 ALLOW TCP 10.0.0.51:40021 -> 198.51.100.77:80
2025-09-22 13:00:00 ALLOW TCP 10.0.0.60:30046 -> 198.51.100.77:4444
2025-09-22 14:04:27 ALLOW TCP 203.0.113.100:51753 -> 10.0.0.60:25
2025-09-22 14:17:26 ALLOW TCP 198.51.100.77:53539 -> 10.0.0.20:25
2025-09-22 15:00:00 ALLOW TCP 10.0.0.51:40022 -> 198.51.100.77:80
2025-09-22 15:46:02 ALLOW TCP 203.0.113.45:59771 -> 10.0.0.20:23
2025-09-22 17:22:11 ALLOW TCP 203.0.113.45:49360 -> 10.0.0.50:22
2025-09-22 17:36:30 ALLOW TCP 203.0.113.100:58709 -> 10.0.0.50:443
2025-09-22 19:00:00 ALLOW TCP 10.0.0.60:30047 -> 198.51.100.77:4444
2025-09-22 19:00:00 ALLOW TCP 10.0.0.51:40023 -> 198.51.100.77:80
2025-09-22 22:48:28 ALLOW TCP 198.51.100.45:64769 -> 10.0.0.51:80

```

- we can now confirm the suspicious IP has been able to gain access into the internal network.

4. I then assessed the VPN logs to verify any failed attempts using the

```
[ cat vpn_auth.log | grep FAIL | cut -d' ' -f3 | sort -nr | uniq -c ]
```

- cat vpn_log reads the contents of the log file
- grep FAIL filters the output to include only lines that contain fail
- cut -d' ' -f3 extracts sections from each line sets the delimiter and selects the 3rd field the IP address.
- sort -nr sorts the IP address with most occurring first
- uniq -c counts the occurrence of each unique IP Address

```

File Edit View Search Terminal Help
ubuntu@tryhackme:~/Desktop/Perimeter_logs/challenge$ cat vpn_auth.log | grep FAIL | cut -d' ' -f3 |
sort -nr | uniq -c
    118 203.0.113.45
     1 203.0.113.100
     1 198.51.100.92
     1 198.51.100.45
ubuntu@tryhackme:~/Desktop/Perimeter_logs/challenge$

```

5. Here we can now see multiple VPN failed login attempts, I then narrowed it down to see who the target was using [cat vpn_auth.log | grep [REDACTED]]

```

File Edit View Search Terminal Help
2025-09-03 02:16:30 203.0.113.45 svc_backup FAIL
2025-09-03 02:16:40 203.0.113.45 svc_backup FAIL
2025-09-03 02:16:50 203.0.113.45 svc_backup FAIL
2025-09-03 02:17:00 203.0.113.45 svc_backup FAIL
2025-09-03 02:17:10 203.0.113.45 svc_backup FAIL
2025-09-03 02:17:20 203.0.113.45 svc_backup FAIL
2025-09-03 02:17:30 203.0.113.45 svc_backup FAIL
2025-09-03 02:17:40 203.0.113.45 svc_backup FAIL
2025-09-03 02:17:50 203.0.113.45 svc_backup FAIL
2025-09-03 02:18:00 203.0.113.45 svc_backup FAIL
2025-09-03 02:18:10 203.0.113.45 svc_backup FAIL
2025-09-03 02:18:20 203.0.113.45 svc_backup FAIL
2025-09-03 02:18:30 203.0.113.45 svc_backup FAIL
2025-09-03 02:18:40 203.0.113.45 svc_backup FAIL
2025-09-03 02:18:50 203.0.113.45 svc_backup FAIL
2025-09-03 02:19:00 203.0.113.45 svc_backup FAIL
2025-09-03 02:19:10 203.0.113.45 svc_backup FAIL
2025-09-03 02:19:20 203.0.113.45 svc_backup FAIL
2025-09-03 02:19:30 203.0.113.45 svc_backup FAIL
2025-09-03 02:19:40 203.0.113.45 svc_backup SUCCESS assigned_ip=10.8.0.23
2025-09-03 02:19:50 203.0.113.45 svc_backup SUCCESS assigned_ip=10.8.0.23
2025-09-03 18:38:57 192.0.2.115 jsmith SUCCESS assigned_ip=10.8.0.102
2025-09-03 19:21:38 198.51.100.92 jsmith SUCCESS assigned_ip=10.8.0.19

```

- Here we can see that a VPN brute force attack was utilized on svc_backup and ended up successful with the attacker gaining access and allocated Ip Address off 10.8.0.23

- Now we confirmed that the internal network was breached I will filter through firewall logs for traces of lateral movement from the compromised host.

[*cat firewall.log | grep svc_backup | grep "ALLOW" | head*]

```

File Edit View Search Terminal Help
ubuntu@tryhackme:~/Desktop/Perimeter_logs/challenge$ cat firewall.log | grep [svc_backup] | grep "ALLOW" | head
ubuntu@tryhackme:~/Desktop/Perimeter_logs/challenge$ cat firewall.log | grep [REDACTED] | grep "ALLOW" | head
2025-08-25 00:47:46 ALLOW TCP 198.51.100.77:60317 -> 10.0.0.50:443
2025-08-25 01:29:33 ALLOW TCP 203.0.113.100:62718 -> 10.0.0.60:443
2025-08-25 01:42:12 ALLOW TCP 203.0.113.100:55075 -> 10.0.0.51:80
2025-08-25 03:30:47 ALLOW TCP 198.51.100.77:63035 -> 10.0.0.20:80
2025-08-25 04:06:58 ALLOW TCP 192.0.2.115:65458 -> 10.0.0.20:25
2025-08-25 05:51:36 ALLOW TCP 203.0.113.100:56035 -> 10.0.0.20:53
2025-08-25 06:09:50 ALLOW TCP 198.51.100.92:63418 -> 10.0.0.60:8080
2025-08-25 07:39:29 ALLOW TCP 198.51.100.77:55955 -> 10.0.0.51:8080
2025-08-25 08:24:34 ALLOW TCP 198.51.100.92:63475 -> 10.0.0.60:8080
2025-08-25 08:57:21 ALLOW TCP 198.51.100.92:58636 -> 10.0.0.50:53
ubuntu@tryhackme:~/Desktop/Perimeter_logs/challenge$ cat firewall.log | grep svc_backup | grep "ALLOW" | head

```

Here we can see the compromised host is probing internal machines 10.0.0.20, 10.0.0.51, 10.0.0.60 on a few ports but the main ones being HTTP, DNS, Web alt HTTPS

- I then went to the ids_alert.logs and filtered the compromised IP to see if any intrusion rules were triggered using the command

[*cat ids_alerts.log | grep [REDACTED] | head*]

```

ubuntu@tryhackme:~/Desktop/Perimeter_logs/challenge$ cat ids_alerts.log | grep 10.8.0.23 | head
2025-09-05 06:00:00 [**] [1:2000200:1] ET SCAN Possible SSH Scan [**] [Classification: Attempted Unauthorized Access] [Priority: 1] [TCP] 10.8.0.23:2000 -> 10.0.0.51:22
2025-09-05 06:10:00 [**] [1:2000201:1] ET EXPLOIT Possible MS-SMB Lateral Movement [**] [Classification: Attempted Unauthorized Access] [Priority: 1] [TCP] 10.8.0.23:2001 -> 10.0.0.51:445
2025-09-05 06:20:00 [**] [1:2000202:1] ET SCAN Possible SSH Scan [**] [Classification: Attempted Unauthorized Access] [Priority: 1] [TCP] 10.8.0.23:2002 -> 10.0.0.60:22
2025-09-05 06:30:00 [**] [1:2000203:1] ET EXPLOIT Possible RDP Brute Force [**] [Classification: Attempted Unauthorized Access] [Priority: 1] [TCP] 10.8.0.23:2003 -> 10.0.0.60:3389
2025-09-05 06:40:00 [**] [1:2000204:1] ET EXPLOIT Possible RDP Brute Force [**] [Classification: Attempted Unauthorized Access] [Priority: 1] [TCP] 10.8.0.23:2004 -> 10.0.0.51:3389
2025-09-05 06:50:00 [**] [1:2000205:1] ET SCAN Possible SSH Scan [**] [Classification: Attempted Unauthorized Access] [Priority: 1] [TCP] 10.8.0.23:2005 -> 10.0.0.20:22
2025-09-05 07:00:00 [**] [1:2000206:1] ET EXPLOIT Possible MS-SMB Lateral Movement [**] [Classification: Attempted Unauthorized Access] [Priority: 1] [TCP] 10.8.0.23:2006 -> 10.0.0.20:445
2025-09-05 07:10:00 [**] [1:2000207:1] ET SCAN Possible SSH Scan [**] [Classification: Attempted Unauthorized Access] [Priority: 1] [TCP] 10.8.0.23:2007 -> 10.0.0.20:22
2025-09-05 07:20:00 [**] [1:2000208:1] ET EXPLOIT Possible RDP Brute Force [**] [Classification: Attempted Unauthorized Access] [Priority: 1] [TCP] 10.8.0.23:2008 -> 10.0.0.20:3389
2025-09-05 07:30:00 [**] [1:2000209:1] ET SCAN Possible SSH Scan [**] [Classification: Attempted Unauthorized Access] [Priority: 1] [TCP] 10.8.0.23:2009 -> 10.0.0.51:22
ubuntu@tryhackme:~/Desktop/Perimeter_logs/challenge$

```

- IDS flagged 3 alerts one includes lateral movement an SMB exploit, I then narrowed it down even further using the

[*cat ids_alerts.log | grep -n 10.8.0.23 | grep 'SMB' | cut -d ' ' -f6,7,8,9,10,19,21 | head*]

```

ubuntu@tryhackme:~/Desktop/Perimeter_logs/challenge$ cat ids_alerts.log | grep -n 10.8.0.23 | grep 'SMB' | cut -d ' ' -f6,7,8,9,10,19,21 | head
EXPLOIT Possible MS-SMB Lateral Movement 10.8.0.23:2001 10.0.0.51:445
EXPLOIT Possible MS-SMB Lateral Movement 10.8.0.23:2006 10.0.0.20:445
EXPLOIT Possible MS-SMB Lateral Movement 10.8.0.23:2010 10.0.0.60:445
EXPLOIT Possible MS-SMB Lateral Movement 10.8.0.23:2016 10.0.0.60:445
EXPLOIT Possible MS-SMB Lateral Movement 10.8.0.23:2018 10.0.0.20:445
EXPLOIT Possible MS-SMB Lateral Movement 10.8.0.23:2020 10.0.0.60:445
EXPLOIT Possible MS-SMB Lateral Movement 10.8.0.23:2021 10.0.0.51:445
EXPLOIT Possible MS-SMB Lateral Movement 10.8.0.23:2027 10.0.0.60:445
EXPLOIT Possible MS-SMB Lateral Movement 10.8.0.23:2033 10.0.0.20:445
EXPLOIT Possible MS-SMB Lateral Movement 10.8.0.23:2035 10.0.0.20:445
ubuntu@tryhackme:~/Desktop/Perimeter_logs/challenge$

```

- As we can see there's multiple alerts for lateral movement, with this I can look further to check for C2 communication I used the command

[*cat ids_alerts.log | grep C2 | head*]

```

ubuntu@tryhackme:~/Desktop/Perimeter_logs/challenge$ cat ids_alerts.log | grep C2 | head
2025-09-11 01:00:00 [**] [1:2001000:1] ET TROJAN Possible C2 Beacons [**] [Classification: A network Trojan was detected] [Priority: 1] [TCP] 10.0.0.60:30000 -> 198.51.100.77:4444
2025-09-11 07:00:00 [**] [1:2001001:1] ET TROJAN Possible C2 Beacons [**] [Classification: A network Trojan was detected] [Priority: 1] [TCP] 10.0.0.60:30001 -> 198.51.100.77:4444
2025-09-11 13:00:00 [**] [1:2001002:1] ET TROJAN Possible C2 Beacons [**] [Classification: A network Trojan was detected] [Priority: 1] [TCP] 10.0.0.60:30002 -> 198.51.100.77:4444
2025-09-11 19:00:00 [**] [1:2001003:1] ET TROJAN Possible C2 Beacons [**] [Classification: A network Trojan was detected] [Priority: 1] [TCP] 10.0.0.60:30003 -> 198.51.100.77:4444
2025-09-12 01:00:00 [**] [1:2001004:1] ET TROJAN Possible C2 Beacons [**] [Classification: A network Trojan was detected] [Priority: 1] [TCP] 10.0.0.60:30004 -> 198.51.100.77:4444
2025-09-12 07:00:00 [**] [1:2001005:1] ET TROJAN Possible C2 Beacons [**] [Classification: A network Trojan was detected] [Priority: 1] [TCP] 10.0.0.60:30005 -> 198.51.100.77:4444
2025-09-12 13:00:00 [**] [1:2001006:1] ET TROJAN Possible C2 Beacons [**] [Classification: A network Trojan was detected] [Priority: 1] [TCP] 10.0.0.60:30006 -> 198.51.100.77:4444
2025-09-12 19:00:00 [**] [1:2001007:1] ET TROJAN Possible C2 Beacons [**] [Classification: A network Trojan was detected] [Priority: 1] [TCP] 10.0.0.60:30007 -> 198.51.100.77:4444
2025-09-13 01:00:00 [**] [1:2001008:1] ET TROJAN Possible C2 Beacons [**] [Classification: A network Trojan was detected] [Priority: 1] [TCP] 10.0.0.60:30008 -> 198.51.100.77:4444
2025-09-13 07:00:00 [**] [1:2001009:1] ET TROJAN Possible C2 Beacons [**] [Classification: A network Trojan was detected] [Priority: 1] [TCP] 10.0.0.60:30009 -> 198.51.100.77:4444

```

- Lateral movement and C2 beacons confirmed we can now narrow this down even further.

[*cat ids_alerts.log | grep -n [REDACTED] | cut -d ' ' -f6,7,8,9,10,19,22,23 | head -n 15*]

```

ubuntu@tryhackme:~/Desktop/Perimeter_logs/challenge$ cat ids_alerts.log | grep -n [REDACTED] | cut -d ' ' -f6,7,8,9,10,19,22,23 | head -n 15
POLICY Suspicious HTTP [**] [Classification:
POLICY Suspicious HTTP [**] [Classification:
INFO Possible Benign Scan [**] 10.0.0.20:21
WEB_SERVER Possible SQL Injection [**] 10.0.0.20:22
POLICY Suspicious HTTP [**] [Classification:
INFO Possible Benign Scan [**] 10.0.0.51:443
WEB_SERVER Possible SQL Injection [**] 10.0.0.60:3389
INFO Possible Benign Scan [**] 10.0.0.50:8080
INFO Possible Benign Scan [**] 10.0.0.51:445
POLICY Suspicious HTTP [**] [Classification:
WEB_SERVER Possible SQL Injection [**] 10.0.0.20:4444
POLICY Suspicious HTTP [**] [Classification:
POLICY Suspicious HTTP [**] [Classification:
INFO Possible Benign Scan [**] 10.0.0.20:25
INFO Possible Benign Scan [**] 10.0.0.50:22
ubuntu@tryhackme:~/Desktop/Perimeter_logs/challenge$

```

10. More suspicious activity confirmed now to pull total statistics off all activities

```
[ cat ids_alerts.log | grep -n [REDACTED] | cut -d' ' -f6,7,8,9,10,19,22,23 | uniq -c | sort -nr | head ]
```

```
ubuntu@tryhackme:~/Desktop/Perimeter_logs/challenge$ cat ids_alerts.log | grep -n [REDACTED] | cut -d' ' -f6,7,8,9,10,19,22,23 | uniq -c | sort -nr | head
 8 TROJAN Possible C2 Beaconsing [**] [TCP] 198.51.100.77:4444
 5 POLICY Suspicious HTTP [**] [Classification:
 4 SCAN Possible SSH Scan [**] ->
 4 POLICY Suspicious HTTP [**] [Classification:
 3 SCAN Possible Portscan [**] [Classification: 10.0.0.20:4444
 3 SCAN Possible Portscan [**] [Classification: 10.0.0.20:4444
 3 SCAN Possible Portscan [**] [Classification: 10.0.0.20:22
 3 SCAN Possible Portscan [**] [Classification: 10.0.0.20:21
 3 POLICY Suspicious HTTP [**] [Classification:
 3 POLICY Suspicious HTTP [**] [Classification:
```

- Evidence suggests the internal network is compromised there's an ip address acting as a C2 server receiving the C2 beacons

11. Now that C2 communication has been confirmed next step is to verify if data has been exfiltrated out the network

```
[ cat firewall.log | grep [REDACTED] | cut -d' ' -f5,6,7 | uniq | sort ]
```

```
ubuntu@tryhackme:~/Desktop/Perimeter_logs/challenge$ cat firewall.log | grep 10.8.0.23 | cut -d' ' -f5,6,7 | uniq | sort
10.8.0.23:2000 -> 10.0.0.51:22
10.8.0.23:2001 -> 10.0.0.51:445
10.8.0.23:2002 -> 10.0.0.60:22
10.8.0.23:2003 -> 10.0.0.60:3389
10.8.0.23:2004 -> 10.0.0.51:3389
10.8.0.23:2005 -> 10.0.0.20:22
10.8.0.23:2006 -> 10.0.0.20:445
10.8.0.23:2007 -> 10.0.0.20:22
10.8.0.23:2008 -> 10.0.0.20:3389
10.8.0.23:2009 -> 10.0.0.51:22
10.8.0.23:2010 -> 10.0.0.60:445
10.8.0.23:2011 -> 10.0.0.20:22
10.8.0.23:2012 -> 10.0.0.51:22
10.8.0.23:2013 -> 10.0.0.51:3389
10.8.0.23:2014 -> 10.0.0.20:22
10.8.0.23:2015 -> 10.0.0.51:22
10.8.0.23:2016 -> 10.0.0.60:445
10.8.0.23:2017 -> 10.0.0.51:22
10.8.0.23:2018 -> 10.0.0.20:445
10.8.0.23:2019 -> 10.0.0.20:22
10.8.0.23:2020 -> 10.0.0.60:445
10.8.0.23:2021 -> 10.0.0.51:445
10.8.0.23:2022 -> 10.0.0.51:3389
10.8.0.23:2023 -> 10.0.0.20:22
10.8.0.23:2024 -> 10.0.0.20:22
10.8.0.23:2025 -> 10.0.0.20:22
10.8.0.23:2026 -> 10.0.0.20:22
```

Here we can confirm that the compromised host svc_backup is sending data though SMB port 445.

CONCLUSION

The investigation confirms a full attack chain:

1. External reconnaissance
2. VPN brute-force attack
3. Credential compromise (svc_backup)
4. Initial access via VPN (10.8.0.23)

5. Internal reconnaissance
6. Attempted lateral movement via SMB
7. Command & Control (C2) communication established
8. Data exfiltration

REMEDIATION

1. Immediate Containment

- **Isolate the compromised host (10.8.0.23)** from the network.
- Block its outbound traffic at firewall level, especially to internal subnets.
- If possible, **disable SMB traffic (port 445)** temporarily between segments until the issue is understood.

2. Stop Lateral Movement / Exfil Path

- Restrict SMB (445) access using firewall rules:
 - Only allow SMB between **trusted file servers and authorized endpoints**
 - Deny workstation-to-workstation SMB traffic entirely
- Implement **network segmentation (VLANs)** so user machines can't directly reach sensitive servers.

3. Credential & Access Control Fixes

- Assume credentials on 10.8.0.23 may be compromised:
 - **Reset passwords / rotate credentials**
 - Revoke any cached tokens or sessions
- Enforce **least privilege** (users should not have unnecessary SMB write access)

4. Endpoint Hardening

- Enable/verify:
 - Antivirus / EDR detection for SMB exploitation tools
 - Host-based firewall rules
- Patch systems (SMB exploits often rely on misconfig or vulnerabilities)

5. Detection Improvements

- Alert on:

- Unusual SMB connections (especially high-port scanning or many connections like 2000–2090 pattern)
- Large file transfers over SMB
- Internal IPs suddenly acting as “clients” to many hosts
- Monitor for **repeated SMB sessions like in your log (many 445 connections)**

6. Logging & Investigation

- Preserve logs from:
 - Firewall
 - Windows Event Logs (if applicable)
 - SMB/file server logs on 10.0.0.51
- Investigate what files were accessed or copied.